

Clase 272 — Ataques WiFi avanzados: Evil Twin y PMKID

Parte: **13 — Seguridad móvil, IoT e inalámbrica** · Fuente: *Hacking Exposed Wireless* (Wright, Cache) y documentación de hcxtools 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Ejecutar ataques modernos contra redes WiFi WPA2/WPA3-PSK en un entorno **propio y controlado**: captura del handshake de 4 vías y del PMKID (sin necesidad de clientes conectados), crackeo offline con hashcat, y montaje de un Evil Twin con portal cautivo para capturar credenciales. El alumno entenderá por qué el PMKID cambió el juego, cómo WPA3-SAE resiste estos ataques, y qué defensas aplicar.

⚠️ **Nota ética y legal:** monta tu propio AP de laboratorio y ataca solo tu red. Capturar handshakes, clonar SSIDs o desautenticar clientes de redes ajenas es ilegal en la mayoría de jurisdicciones. Nunca operes sobre redes que no controlas.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Poner** una tarjeta WiFi en modo monitor y capturar tráfico 802.11.
- 2. **Capturar** un handshake WPA2 de 4 vías y un PMKID.
- 3. **Crackear** el hash resultante offline con hashcat.
- 4. **Montar** un Evil Twin con portal cautivo en laboratorio.
- 5. **Explicar** por qué WPA3-SAE mitiga el crackeo offline.
- 6. **Recomendar** defensas (contraseñas fuertes, WPA3, 802.1X, PMF).

📖 Temas

#	Tema	Por qué importa
1	802.11, modo monitor e inyección	Base de toda auditoría WiFi
2	Handshake WPA2 de 4 vías	Material para crackeo offline
3	Ataque PMKID (clientless)	Captura sin clientes conectados
4	Crackeo con hashcat	Convertir captura en contraseña
5	Evil Twin y portal cautivo	Robo de credenciales/phishing WiFi
6	WPA3-SAE y PMF	Por qué resisten los ataques clásicos
7	Defensas y detección	Endurecer la red propia

Definiciones y características

- **Modo monitor:** estado del adaptador que captura todos los frames 802.11 del canal. Característica: prerequisite para sniffing e inyección.
- **Handshake de 4 vías:** intercambio WPA2 que deriva las claves de sesión a partir del PSK. Característica: capturable durante la asociación de un cliente.
- **PMKID:** identificador incluido opcionalmente por el AP en el primer mensaje EAPOL, derivado del PMK. Característica: permite crackeo offline sin clientes.
- **hcxdumpool/hcxtools:** utilidades para capturar PMKID/handshakes y convertirlos al formato de hashcat. Característica: automatizan la captura clientless.
- **Evil Twin:** AP falso que imita el SSID legítimo para atraer clientes. Característica: combinado con portal cautivo, captura credenciales.
- **WPA3-SAE (Dragonfly):** handshake con autenticación simultánea de iguales resistente a diccionario offline. Característica: elimina el crackeo del handshake capturado.

Herramientas y preparación

- **Adaptador WiFi** con soporte de modo monitor e inyección (chipsets Atheros/Ralink/MediaTek), **AP propio** de laboratorio.
- **Aircrack-ng**, **hcxdumpool/hcxtools**, **hashcat**, **hostapd/hostapd-mana** o **wifiphisher** para Evil Twin.

```
# Modo monitor
sudo airmon-ng start wlan0
sudo airodump-ng wlan0mon           # descubrir tu AP y su canal

# Captura de handshake (tu red)
sudo airodump-ng -c 6 --bssid AA:BB:CC:DD:EE:FF -w cap wlan0mon
# (opcional, tu propio cliente) forzar reconexión:
sudo aireplay-ng --deauth 3 -a AA:BB:CC:DD:EE:FF wlan0mon

# Captura de PMKID
sudo hcxdumpool -i wlan0mon -o pmkid.pcapng --enable_status=1
hcxpcapngtool -o hash.hc22000 pmkid.pcapng

# Crackeo offline
hashcat -m 22000 hash.hc22000 wordlist.txt
```

Laboratorio guiado

1. **Prepara el laboratorio:** configura tu propio AP con WPA2-PSK y una contraseña de prueba que esté en tu diccionario.
2. **Modo monitor:** activa `airmon-ng` y localiza tu AP y su canal con `airodump-ng`.
3. **Captura el handshake:** filtra por tu BSSID/canal y provoca la reconexión de **tu** cliente con una deauth breve.
4. **Captura el PMKID:** con `hcxdumpool` obtén el PMKID de tu AP sin clientes y conviértelo a `.hc22000`.
5. **Crackea offline:** usa hashcat modo 22000 con un diccionario; recupera la contraseña de prueba.

6. **Evil Twin:** con hostapd/wifiphisher levanta un AP con el mismo SSID y un portal cautivo en laboratorio aislado; observa el flujo de captura de credenciales con un cliente de pruebas propio.
7. **Compara con WPA3:** reconfigura el AP a WPA3-SAE e intenta el mismo ataque; constata que el crackeo offline ya no aplica.
8. **Documenta** defensas: contraseñas largas, WPA3, PMF obligatorio, 802.1X.

Ejercicios

1. Pon tu adaptador en modo monitor y lista las redes de tu entorno de laboratorio.
2. Captura un handshake de 4 vías de tu propia red.
3. Obtén el PMKID de tu AP y conviértelo al formato de hashcat.
4. Crackea el hash con un diccionario y mide el tiempo.
5. Levanta un Evil Twin con portal cautivo en laboratorio.
6. Repite el ataque contra WPA3 y explica por qué falla.

Reto verificable

Sobre tu **propia** red WPA2, captura el PMKID, conviértelo y recupera la contraseña con hashcat. **Criterio de aceptación:** hashcat muestra la clave crackeada correspondiente a la contraseña que configuraste, y explicas la diferencia con el intento equivalente sobre WPA3-SAE, que no debe ser crackeable offline.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
No entra en modo monitor	Chipset sin soporte; usa un adaptador compatible y mata procesos con <code>airmon-ng check kill</code>
Handshake no válido	Captura incompleta; asegura los 4 mensajes EAPOL o usa PMKID
PMKID vacío	El AP no lo expone o usa WPA3; prueba el handshake tradicional
hashcat muy lento	Diccionario/hardware; usa GPU y reglas, o un diccionario dirigido
Evil Twin sin clientes	Señal débil o PMF activo; ajusta potencia en tu laboratorio aislado

Preguntas frecuentes

? ¿El ataque PMKID necesita clientes conectados? No: esa es su ventaja. Se obtiene directamente del AP si este incluye el PMKID, permitiendo crackeo offline sin esperar a un handshake.

? ¿WPA3 es inmune a todo esto? Elimina el crackeo offline del handshake gracias a SAE, pero no a contraseñas triviales ni a todos los fallos de implementación (p. ej. Dragonblood). Sigue siendo mucho más resistente que WPA2.

? ¿Por qué el Evil Twin funciona incluso con WPA2 fuerte? Porque ataca al usuario, no al cifrado: si la víctima se conecta al AP falso e introduce credenciales en un portal, la fortaleza del cifrado del AP legítimo es irrelevante. PMF y verificación de servidor lo mitigan.

Referencias

- Aircrack-ng: <https://www.aircrack-ng.org/>
- hcxumptool/hcxtools: <https://github.com/ZerBea/hcxumptool>
- hashcat (modo 22000): https://hashcat.net/wiki/doku.php?id=cracking_wpawpa2
- *Hacking Exposed Wireless* — Joshua Wright, Johnny Cache.

Siguiente clase

Clase 273 - Seguridad de sistemas de control industrial (ICS/SCADA)